```markdown

# Security Architecture & Threat Model

## 1. STRIDE Threat Model

| THREAT | ASSET | ATTACK PATH | MITIGATION |
|---|---|---|---|
| **Spoofing** | User Identity | Stolen session token | Short-lived JWTs, secure httpOnly cookies, MFA for admins. |
| **Tampering** | Token Payload | Modify token in transit | Ed25519 signatures, TLS 1.3. |
| **Repudiation** | Audit Logs | Delete logs | Append-only tables, DBA restricted access, log shipping. |
| **Info Disclosure** | PII | SQLi / IDOR | Parameterized queries, strict RBAC, field-level masking. |
| **DoS** | API | Flood requests | Rate limiting, WAF, outbox backpressure. |
| **Elevation** | Admin Rights | Role manipulation | Server-side RBAC checks on every endpoint. |

## 2. Key Security Requirements

- **Keys**: Ed25519 private keys stored in KMS/HSM or encrypted at rest with envelope encryption. Never in code.
- **Auth**: Passwords hashed with Argon2id.
- **Input**: Strict validation, output encoding for XSS prevention.
- **Privacy**: No PII in logs, URLs, or tokens. Use `subject_ref` (hashed ID) in tokens.
```